ERHVERVSAKADEMI
AARHUS

Modul 5 Økonomi i en sikkerhedskontekst

Forretningsforståelse



ERHVERVSAKADEMI
AARHUS

Agenda for i dag.

1. MC - ORG
2. Hjemmeopgave
3. Sikkerhed og økonomi
4. Hvordan laver jeg en business case

ERHVERVSAKADEMI AARHUS

Hjemmeopgave case (gruppeøvelse)

Case: Rigshavn Hospital

Baggrund:
Rigshavn Hospital er et af landets største universitetshospitaler med ca. 6.500 ansatte. Hospitalet har eksisteret i mere end 100 år og er en central aktør i både patientbehandling, forskning og uddannelse.

Nuværende situation:

Størrelse og organisering:

- Hospitalet er opdelt i specialiserede afdelinger (kardiologi, ortopædi, onkologi osv.), hver ledet af en overlæge og en administrativ leder.
- De fleste beslutninger om behandlingsmetoder ligger hos de enkelte afdelinger, mens overordnede strategiske beslutninger træffes af hospitalsledelsen.

Koordination: Arbejdet er i høj grad baseret på professionel standardisering: Læger, sygeplejersker og andet sundhedspersonale er uddannet efter nationale og internationale standarder.

Kultur: Faglig autonomi vægtes højt – overlæger og speciallæger har stor frihed i forhold til valg af behandlingsmetoder, så længe de følger anerkendte retningslinjer.

Omgivelser: Hospitalet er under pres fra politiske reformer, nye cybersikkerheds krav, krav om effektivisering.

Samtidig kræves innovation inden for digital sundhed og tværfaglig behandling.

Udfordringer:

- Vanskeligheder med at koordinere på tværs af afdelinger, da hver afdeling har stærk faglig kultur.
- Lange beslutningsprocesser ved tværgående initiativer (fx indførelse af ny digital patientjournal).
- Spændinger mellem administrative krav om effektivisering og personalets ønske om at prioritere faglig kvalitet.

ERHVERVSAKADEMI
AARHUS

Hjemmeopgave (gruppeøvelse)

Identificer:

•Hvilken af Mintzbergs organisationsstrukturer beskriver bedst Rigshavn Hospital?
•Er der elementer, som trækker i retning af en anden struktur?

Begrund:

Peg på konkrete træk i casen (fx standardisering, professionel autonomi, specialisering).

Svar på:

•Hvilke fordele og ulemper giver denne struktur i forhold til hospitalets mål om både kvalitet, effektivitet og innovation?

•Hvis hospitalet skal blive mere tværfagligt og digitalt, kunne en anden struktur så være mere hensigtsmæssig?

•Hvordan ville du gribe sikkerhedsopgaven an som ny konsulent på hospitalet? (informationsindsamling, videnscentre, kritiske områder, kerne processer/områder) etc.
Med den viden I har indtil nu.

ERHVERVSAKADEMI
AARHUS

Hvorfor er økonomi vigtigt ifm. sikkerhed

Cybersikkerhed handler ikke kun om teknik, men også om at vurdere, hvad sikkerhed er værd – i kroner og øre – både på virksomhedsniveau og samfundsniveau.

1. Ressourceallokering og investeringer

Virksomheder og offentlige organisationer har begrænsede budgetter og må prioritere, hvor meget de vil bruge på sikkerhed frem for andre forretningsområder.

2. Omkostninger ved cyberangreb

Cybersikkerhed er en investering i, at undgå meget større fremtidige tab.

3. Økonomiske incitamenter og risikostyring

Ledere vurderer typisk cybersikkerhed ud fra en cost-benefit-analyse: Hvad koster et sikkerhedstiltag, og hvad er sandsynligheden/konsekvensen af et brud?

4. Nationaløkonomi og samfundsmæssige konsekvenser

Cyberangreb på kritiske områder f.eks hospitaler og banker kan få store økonomiske konsekvenser på samfundsniveau.

ERHVERVSAKADEMI
AARHUS

Typiske sikkerhedsomkostninger - oversigt

1 Omkostninger ved investering i sikkerhed



- **Initial investering:** Implementering af sikkerhedsforanstaltninger.
- **Løbende omkostninger:** Løn, licenser, uddannelse, certificeringer og abon. Etc.

2 Risikoafvejning: Investering vs. Potentielle tab



- **Direkte tab** som følge af tyveri af data eller penge.
- **Indirekte tab** som følge af tabt omdømme/ kunder.
- **Regulering og bøder** som følge af lovovertrædelser.

3 Omkostninger ved hændelser og genopretning



- **Hændelses-omkostninger**
- **Genopretning og driftstab**

4 Forsikring og rådgivning



- **Cyberforsikring**
- **Rådgivning udefra**

5 Compliance-omkostninger



- **Overholdelse af lovgivning**
- **Overholdelse af egne politikker**

Opgave 1

ERHVERVSAKADEMI AARHUS

Bordøvelse (flip over opgave) – 40 minutter.

1. Vurder de forskellige sikkerheds incidents og sårbarheder (se evt. posters opgaven i modul 3) i Hvedebro. Du skal forholde dig 3 områder (incidents) med hensyn til risiko (sandsynlighed for at det sker (lille 1- høj 5) og konsekvens hvis det skete (lille 1 – stor 5), hvis muligt.
   - Hvilke **risici** vurderer du som mest kritiske for virksomheden, og hvorfor?

2. Hvor burde Hvedebro investere i sikkerhedstiltag, hvilke risikomitigerende tiltag[1)] vil du foreslå og hvad vil implementeringen af disse medføre (Lav en top 5 liste)?

3. Undersøg hvad en cyberforsikring er og typisk dækker. Er der områder der er relevante for Hvedebro?

4. Undersøg hvem der kan tilbyde ekstern rådgivning omkring cybersikkerhed. Hvad ville du bruge ny konsulentbistand til i Hvedebro?

Brug 30 minutter på forberedelse. Derefter gennemgang af 2 bordes løsninger. 10 Minutter.

[1)] jf. de 4 muligheder nævnt i modul 1, billede 33, samt
Boman, N. G., & Dirac, M. D. (2024). *Cybersikkerhed – helt sikkert! En praktisk grundbog,* s. 161 (afsnittet "Fase 3: Risikohåndtering")

ERHVERVSAKADEMI
AARHUS

Omkostnings/indtægts påvirkninger (incident)



Omdømme:

Kunder kan miste tilliden til virksomheder med svage cybersikkerheds-foranstaltninger.



Tab af kunder:

Kan have langsigtede konsekvenser for salget og brandværdi.



Nedetid og driftstop:

Cyberangreb kan resultere i nedetid af IT-systemer, hvilket stopper arbejdsprocesser og produktivitet.



Udbedring:

Opgaver som at genoprette systemer og identificere sikkerhedsbrud tager tid og ressourcer.



Påvirkning af medarbejdernes arbejde:

Cyberangreb kan forhindre dem i at udføre deres opgaver.

ERHVERVSAKADEMI
AARHUS

Opgave 2

2 og 2 øvelse.

Gå på nettet og find 1 virksomhed der har været ramt af cyberangreb, og beskriv hvad der skete, og hvordan de var påvirket indenfor de 5 områder på forrige slide. Hvad var konsekvensen (impact)? Hvad har de gjort?

Brug CIA modellen i din forklaring omkring hvordan virksomheden blev ramt, hvis muligt.

15 minutter til forberedelse. 3 minutter til hvert team omkring bordet til af forklare de andre om jeres løsning.

ERHVERVSAKADEMI AARHUS

Langsigtede negative påvirkninger (angreb)

TAB AF MARKEDSANDELE:

VIRKSOMHEDER, DER IKKE BESKYTTER DERES DATA, RISIKERER AT MISTE KUNDER TIL MERE SIKRE KONKURRENTER.

ØGEDE FORSIKRINGSPRÆMIER:

EFTER ET CYBERANGREB KAN VIRKSOMHEDER OPLEVE HØJERE FORSIKRINGS-OMKOSTNINGER, DA DE ANSES FOR AT HAVE HØJERE RISICI.

STØRRE INVESTERINGER:

VIRKSOMHEDER SKAL INVESTERE I AVANCEREDE CYBERSIKKERHED SLØSNINGER, HVILKET KRÆVER RESSOURCER OG KAN PÅVIRKE LIKVIDITETEN PÅ KORT SIGT.

ERHVERVSAKADEMI AARHUS

Positiv påvirkning af virksomheden

CYBERSIKKER-HED SOM EN KONKURRENCE-FORDEL:

VIRKSOMHEDER MED STÆRK CYBERSIKKERHED TILTRÆKKER KUNDER OG FORRETNINGS-PARTNERE, DER PRIORITERER BESKYTTELSE AF DATA.

STØRRE TILLID:

EN ROBUST CYBERSIKKERHEDS STRATEGI ØGER TILLIDEN BLANDT KUNDER OG INVESTORER.

LANGSIGTET BESKYTTELSE:

VIRKSOMHEDER, DER PRIORITERER CYBERSIKKERHED , ER BEDRE RUSTET TIL AT MODSTÅ FREMTIDIGE ANGREB OG OPNÅ VÆKST.

ERHVERVSAKADEMI
AARHUS

Hvordan får man midler til sikkerhed



Sikkerhed er oftest en udgift, som kan anses som en ”forsikring” mod angreb

Når man ”kæmper” om virksomhedens midler, skal argumentation være god og saglig.

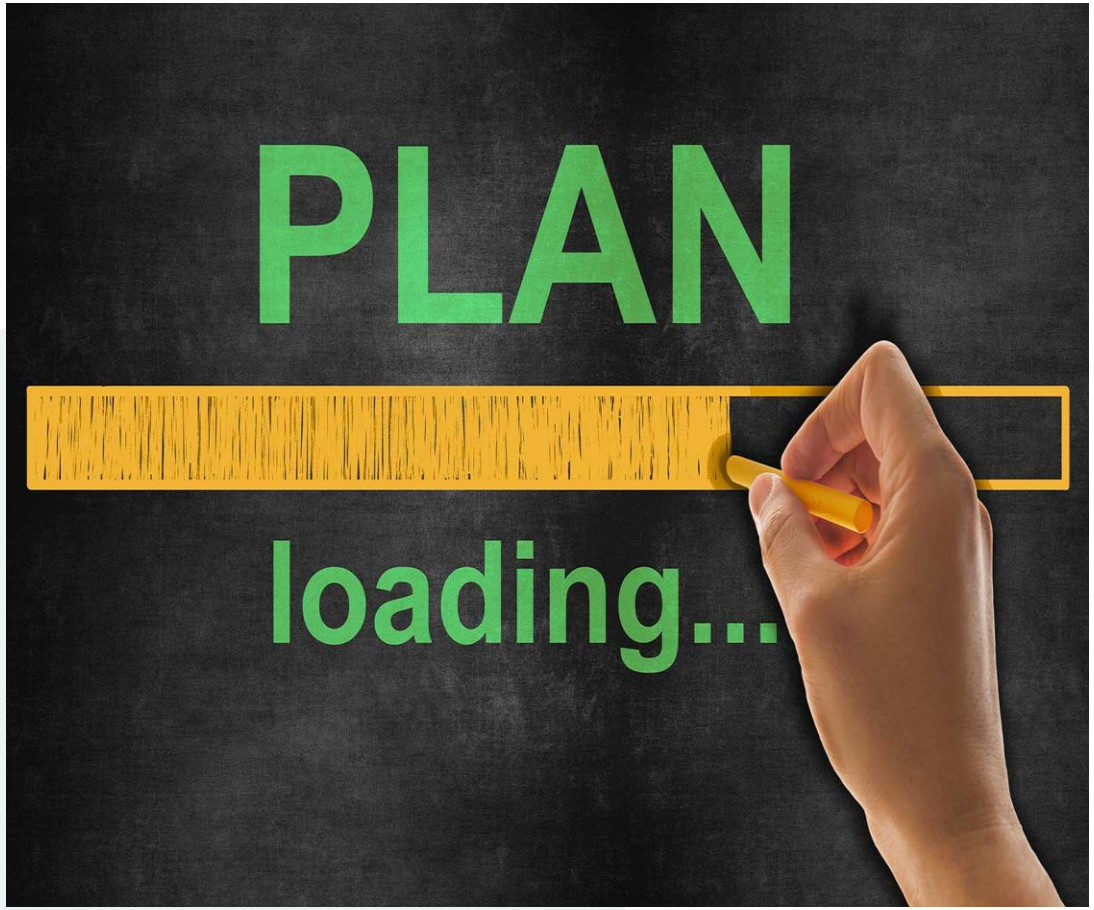
Virksomheder har forskellige modeller til udarbejdelse af indstilling = business case.

Det er vigtig at kunne forklare trusler, sårbarheder og risikovurdering i indstillingen.

Der er et grundprincip om at man ikke vil bruge 2 kroner på at beskytte 1 krone, så et billede af konsekvens ved angreb er vigtigt. (kan være vanskeligt at angive præcist)

ERHVERVSAKADEMI
AARHUS

Businesscase på Cybersikkerhed



Formål: At argumentere for investering i cybersikkerhed

Cybersikkerhed er en forretningskritisk disciplin

Målgruppe: Ledelse, bestyrelse, beslutningstagere

ERHVERVSAKADEMI
AARHUS

Proces for udvikling af businesscase

1. Hvad er problemet/risiko?
2. Hvad er konsekvens hvis hændelse opstår?
3. Hvad skal der gøres / investeres i?
4. Hvorfor er det en god case?
5. Beslutningsgrundlag og næste skridt

ERHVERVSAKADEMI
AARHUS

1. Hvad er udfordringen?



Kortlægning af aktuelle trusler der skal imødekommes (trusselsbillede). Eks. ransomware, phishing, insidertrusler

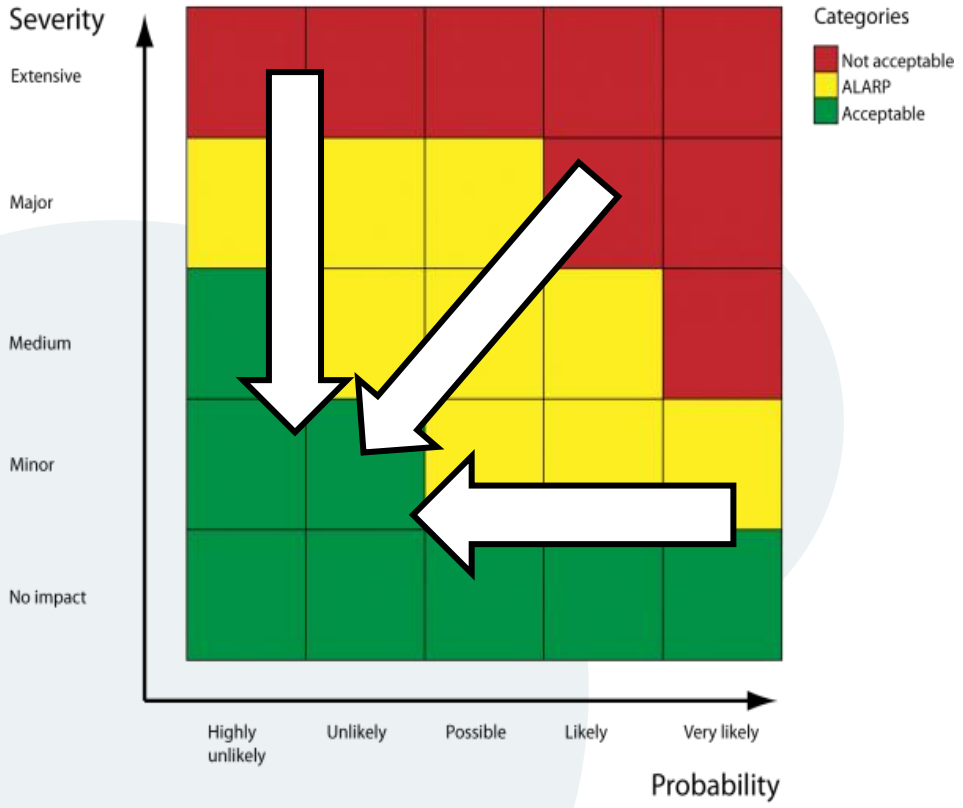
Vis risikoscore, så det belyses at du kigger på det vigtigste (sandsynlighed x konsekvens) (mere om det senere)

Identificer hvor virksomheden er sårbar

Konsekvenser ved angreb eks. økonomisk tab, omdømme, driftsforstyrrelser etc.

Eksempel: "Et cyberangreb på dette område kan koste virksomheden X kr. i tabt omsætning.

2. Konsekvensanalyse



Beregn/estimer økonomisk påvirkning ved hændelse

Overvej både direkte og indirekte omkostninger (bøder, reetablering, mistede kunder etc.)

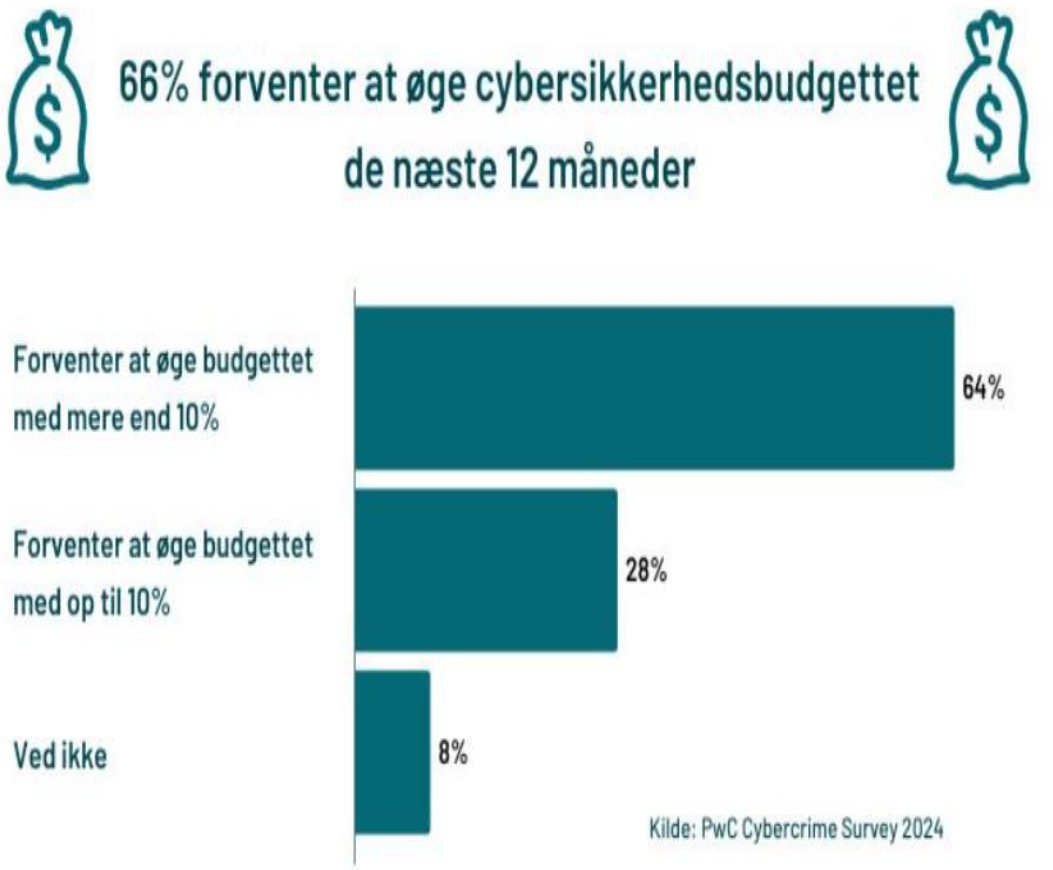
Worst-case, most-likely og best-case scenarier (spænd for konsekvensscenarier)

Brug gerne en tabel eller graf.

ALARP betyder As Low As Reasonable Practicable,
at risikoen skal reduceres så meget, som det med rimelighed og i praksis er muligt.

ERHVERVSAKADEMI
AARHUS

3. Hvad skal der gøres/ investeres i ?



Eks. awareness-træning, firewall-opgraderinger, penetrationstest osv.

Hvilke trusler adresseres af hver indstillet løsning?

Estimerede omkostninger for hver løsning.

Prioritér løsninger efter effekt og pris.

ERHVERVSAKADEMI AARHUS

4. Hvorfor er det en god case
Return on Security Investment (ROSI)

- **Sammenligner** investeringen med potentielle tab

ROSI = (ALE x mitigeringsgrad – investering) / investering

Variablerne og deres enheder

Størrelse	Hvad det er	Regnes i
SLE (Single Loss Expectancy)	Tab pr. hændelse	kr.
ARO (Annual Rate of Occurrence)	Antal hændelser pr. år	antal (må gerne være under 1)
ALE (Annual Loss Expectancy) = SLE x ARO	Forventet årligt tab **uden** tiltaget	kr. pr. år
Mitigeringsgrad	Hvor stor en del af tabet tiltaget fjerner	decimaltal mellem 0 og 1 (60 % skrives 0,60)
Investering	Løsningens **årlige** omkostning: Eks. licens, drift, interne timer, uddannelse	kr. pr. år
ROSI	Nettoafkast pr. investeret krone	decimaltal uden enhed

Sådan læses resultatet

- **ROSI er et decimaltal.** Gang med 100, hvis du vil skrive det i procent: 1,4 = 140 %.
- **ROSI + 1** = undgået tab pr. investeret krone: 1,4 + 1 = 2,40 kr.
- **ROSI større end 0**: tiltaget tjener sig hjem inden for et år.

ERHVERVSAKADEMI AARHUS

Regneeksempel: ROSI på et tiltag i Hvedebro

Størrelse	Værdi	Enhed
SLE	400.000	kr. pr. hændelse
ARO	0,5 (én hændelse hvert andet år)	antal pr. år
ALE = SLE x ARO	**400.000 x 0,5 = 200.000**	**kr. pr. år**
Investering (awareness-træning)	50.000	kr. pr. år
Mitigeringsgrad	0,60 (svarer til 60 %)	decimaltal
Undgået tab = ALE x mitigeringsgrad	**200.000 x 0,60 = 120.000**	**kr. pr. år**
ROSI	**(120.000 - 50.000) / 50.000 = 1,4**	**decimaltal**

Hvad betyder en ROSI på 1,4?

- **Du investerer 50.000 kr.** og undgår tab for 120.000 kr.
- **120.000 / 50.000 = 2,40 kr.** undgået tab pr. investeret krone.
- Af de 2,40 kr. dækker 1,00 kr. selve investeringen. Tilbage står **1,40 kr.** Det er ROSI – altså nettoafkastet, ikke det samlede undgåede tab.

Tre ting, der typisk går galt

- **Mitigeringsgraden** skal indtastes som decimaltal. 60 % er **0,60**, ikke 60.
- **ALE** er tabet **før** tiltaget. Undgået tab findes først, når mitigeringsgraden er ganget på.
- **Både tab og investering** skal være årlige tal.

Omregning af resultaterne fra opgave 1 til kroner:. Konsekvens 1-5 omsættes til et vurderet kronebeløb, sandsynlighed 1-5 til hændelser pr. år (forslag: 1 ≈ 0,1/år, 3 ≈ 0,5/år, 5 ≈ 2/år).

5. Beslutningsgrundlag og næste skridt



Opsummer behovet og forretningsværdien

Klar anbefaling (f.eks. investering på X kr. over Y måneder)

Næste skridt: Godkendelse, planlægning, implementering

Slut med en stærk konklusion og opfordring til handling

- **Effekt**: Cybersikkerhed beskytter indtjening og drift
- **Case**: Et konkret eksempel styrker argumentationen

ERHVERVSAKADEMI
AARHUS

Opgave 3

Gå sammen ved bordet.

Lav en indstilling **på 3 forbedringer i Hvedebro** i forhold til deres incidents. Brug estimerede tal på mitigeringsomkostninger og tab. Arbejdet med modellen er det vigtigste. Brug evt. de erfaringer I gjorde i opgave 1.

Reflektér over din egen rolle: Hvis du var IT-chef eller sikkerhedsansvarlig, hvordan ville du så **præsentere businesscasen** for at få ledelsens opbakning?

Hvordan kan virksomheden argumentere overfor bestyrelsen for, at cybersikkerhed ikke kun er en udgift, men en **investering**?

Lav en PPT præsentation – så flot I kan (den er til direktionen ☺) og send den til hhv. Frank Elkær (frae@eaaa.dk) eller Frank Lund (frlu@eaaa.dk) . **Brug evt. skabelon i Canvas som ramme for PPT.**

30 minutter til forberedelse. Derefter gennemgår vi et par stykker.

Keep it simple.



ERHVERVSAKADEMI
AARHUS

Wrap up på sikkerhedsøkonomi

Luk computeren

Hvilke omkostnings elementer er der på cybersikkerhed?

Hvilke **forretningsmæssige konsekvenser** (økonomi, drift, image, kunder) kan virksomheden opleve ved ikke at investere i højere cybersikkerhed?

Hvilke overvejelser er vigtige, når man søger midler til cybersikkerhed?

Hvad er ROSI?

Hvad bør man have med i konsekvensanalysen i sin businesscase?

Hvad har du selv lært af at arbejde med casen, som du kan overføre til fremtidige beslutninger om cybersikkerhed?